

Informe de pendientes — Procurador SCW

Documento de estado · 2026-07-11 · Fuente: `CLAUDE.md` (guía maestra del proyecto) + `docs/internal/informe-bugs-2026-07.md`
Versión app Electron: **2.7.36** (GitHub Releases, auto-updater activo) · Versión extensión Chrome: **1.3.5** (⌚ en revisión de Google; en store activa: 1.3.4)

0. Resumen ejecutivo

Categoría	Cantidad	Bloquea comercialización
Requieren cuentas/contratos externos	3	B3 sí (pago real)
Infraestructura técnica	5 (2 cerrados)	No
Seguridad pre-comercialización	3 abiertos (5 cerrados)	Sí (SEC-4)
Bugs relevados (informe 2026-07-10)	26 (2 críticos, 6 altos, 10 medios, 8 bajos)	Sí (C1, C2+A1+M4 antes de B3)
Flecos de QA integral	1 bloqueado + varios menores	No
Propuestas de producto sin aprobar	1 (módulo Bitácora)	No
Diferidos al lanzamiento público	2	Sí, por diseño

Lo más urgente para destrabar la comercialización real (B3 = MercadoPago producción):

- Corregir **C1** (bonus por submódulo cancelado — uso ilimitado sin contar).
- Corregir el paquete **C2 + A1 + M4** (el webhook pierde pagos aprobados, la suscripción no queda bien seteada tras el primer pago, sin transacción) — es el camino exacto que recorrerá el primer cobro real.
- Resolver **SEC-4** (enforcement del trial es solo client-side hoy).

1. Requieren cuentas o contratos externos

#	Tarea	Estado / detalle
B3	MercadoPago producción	Sandbox validado end-to-end. Falta activar credenciales reales + <code>PAYMENT_MODULE_ENABLED=true</code> . Prerequisito de código: corregir C1, C2, A1, M4 antes de exponer dinero real.
C1 (contrato)	Contrato Facturante	No bloqueante — facturación manual (admin sube PDF de ARCA) funciona en producción. Activar cuando se contrate: completar <code>FACTURANTE_*</code> + descomentar cron <code>invoice-retry</code> .
AZ	Azure Trusted Signing	Code signing del instalador <code>.exe</code> . Elimina el warning de Windows SmartScreen. Trámite con tiempos externos (certificado 1-3 días hábiles) — conviene iniciarlo con anticipación.

2. Infraestructura técnica

#	Tarea	Prioridad	Estado
D1	<code>ALTER DEFAULT PRIVILEGES</code> en DB (evita grants manuales en migraciones futuras)	Baja	Pendiente
D2	SSL <code>api.procuradortool.com</code>	—	✅ Resuelto — certbot renueva solo, vence 2026-08-28
D3	<code>npm audit fix</code> (sin <code>--force</code>)	Media	Pendiente — empeoró desde junio : backend 19 vulnerabilidades (10 high), electron-app 26 (16 high + 1 critical). Casi todo tiene fix directo sin breaking changes.
D4	<code>npm audit fix --force</code> controlado (mercadopago/uuid, axios, undici, electron)	Baja	Pendiente — requiere probar el flujo de pagos completo en staging tras actualizar
D5	Limpiar temporales del repo (<code>seed_legal_tmp.js</code> , <code>test_legal_tmp.js</code> , <code>test_legal_full_tmp.js</code>)	Baja	Pendiente
D6	Carpeta de descargas por usuario (CUIT)	—	✅ Resuelto (release v2.7.30)

Nota de esta revisión: además de los `.js` temporales de D5, hay varios archivos sin trackear en git que conviene revisar (`ext-header-preview.png` , `extension-app/imagenes/old/` , capturas sueltas en `tests/*.png` , carpeta `tests/tests/` que parece duplicada).

3. Staging y rollback

Cerrado — entorno completo operativo (4 fases): `staging-api.procuradortool.com` , backups pre-deploy, restore probado, rollback bidireccional. Sin pendientes en este bloque. Documentación: `docs/internal/flujo-staging-rollback.md` , `docs/internal/runbook-comandos.md` .

4. Seguridad pre-comercialización

#	Tarea	Estado
M-1, M-2, B-1 a B-8	Grupo de hardening (blacklist, HMAC timing-safe, bcrypt cost, TLS, política de contraseñas, CSP, etc.)	✅ Todos resueltos
SEC-1	Auditoría de seguridad (7 bloques white+black-box contra staging)	Plan ejecutable listo en <code>docs/internal/plan-seguridad-precomercializacion-2026-07.md</code> . No ejecutado.
SEC-2	Smoke tests CI (GitHub Actions) + verificación diaria real contra el PJN	Plan listo (mismo doc, Parte B). Requiere release Electron para la Parte B.2.
SEC-3	Hardening de secretos	✅ Verificado — sin secretos hardcodeados
SEC-4	Mover enforcement del trial a <code>/license/execution/start</code>	Pendiente, marcado pre-lanzamiento. El informe de bugs 2026-07-10 encontró que el problema es peor de lo documentado: la rama de submódulo de <code>log-execution</code> tampoco frena el trial contra el tope de 20 (hallazgo M2) — gatea contra los límites del plan pago en vez del trial.

Orden sugerido para retomar: **SEC-4** → **SEC-1** → **SEC-2** (doc: `plan-seguridad-precomercializacion-2026-07.md`).

5. Informe de bugs (2026-07-10) — pendiente de corrección

Documento completo: `docs/internal/informe-bugs-2026-07.md` . Relevado por 3 revisores en paralelo (backend cobranza/auth · backend ejecución/cuotas · app Electron), con verificación manual línea por línea de cada hallazgo alto/crítico.

Críticos (2)

id	Resumen	Ubicación
C1	El bonus (<code>*_bonus</code>) por submódulo se cancela algebraicamente en el gate de cuota → cualquier cuenta con bonus asignado obtiene ejecuciones ilimitadas sin que se cuenten, una vez que supera el límite base	<code>client.js:359</code>
C2	El webhook de MercadoPago descarta el evento <code>approved</code> cuando llega después de un <code>pending</code> para el mismo <code>payment.id</code> → el pago se pierde y la cuenta no se activa aunque el dinero haya entrado	<code>webhooks.js:110</code>

Altos (6)

id	Resumen
A1	<code>applyTrialBonus</code> no setea <code>next_billing_date</code> / <code>status</code> en el primer pago → rompe cancelar, pausar y reactivar durante el primer período
A2	El claim de pago "por ventana de checkout" no tiene techo temporal y el timestamp de referencia nunca se limpia → un usuario puede terminar reclamando el pago de otro
A3	<code>linkPreapproval</code> no valida que el preapproval pertenezca al usuario (IDOR)
A4	<code>/auth/forgot-password</code> : XSS reflejado + enumeración de emails + sin rate limit
A5	La variable de guardia de concurrencia (<code>currentProcess</code>) es código muerto → la app no bloquea ejecuciones simultáneas
A6	<code>shutdown()</code> nunca se invoca al cerrar la app → el script y Chrome quedan huérfanos, el lock del servidor queda tomado

Medios (10) y bajos (8)

Incluyen: reset mensual global que ignora el ciclo de facturación real (M1), el trial no enforzado server-side en la rama de submódulo (M2, refuerza SEC-4), condición de carrera en el lock de ejecución (M3), falta de transacción en el flujo de pago aprobado (M4), cache de CUIT que puede cruzar carpetas de descargas entre usuarios (M5), y otros de menor impacto — detalle completo en el documento.

Plan de arreglo sugerido

1. **C1** — fix de una línea, solo backend, sin release.
2. **C2 + A1 + M4** — mismo paquete (camino del primer pago real), solo backend. **Prerequisito de B3.**
3. **A4** — fix rápido de seguridad, solo backend.
4. **A2 + A3** — integridad del flujo de cobro, solo backend.
5. **A5 + A6** — requieren **release de Electron**.
6. **M1 + M2** — monetización / SEC-4, solo backend.
7. Resto de medios y bajos — lote posterior.

6. Fleclos del plan de pruebas integral (2026-07-03/04)

Documento: `docs/internal/plan-pruebas-integral-2026-07.md`. Cobertura muy alta, con estos casos sin cerrar:

- **U9.3** (bloqueante real): pagar una reactivación falla por una causa aún no identificada en el flujo — no es el mismo bug ya corregido en la sesión de hallazgos.
- Menores, sin bloquear: A1.14 (ciclo completo de reset de contraseña), A7.5 (rate limit del bot IA, no ejecutado por costo), A2.6/A2.8, A4.4/A4.5, A3.10/A3.11, U5.3, U11.7 (confirmaciones visuales pendientes, no son bugs).
- Suelto de cobranza: límite `monitor_partes` (bloqueo en la 21ª parte), cambio de plan 2/ciclo + cancelar downgrade programado, idempotencia de pagos (mismo webhook 2 veces no debe duplicar — relacionado con C2 del informe de bugs), downgrade→upgrade (requiere un 3er plan tarifado activo, ver L1).

7. Propuestas de producto sin aprobar

Módulo Bitácora (agenda, tareas, gestiones y notas por expediente)

Documento: [docs/internal/propuesta-bitacora-agenda-2026-07.md](#) (v6.1) + PDF regenerado. **Estado: borrador completo, no aprobado, no en desarrollo.**

Cubre: entradas de bitácora (vencimientos, audiencias, tareas, gestiones, notas) + expedientes seguidos con ficha liviana por caso, captura desde los 4 visores por deep-link (individual y selección múltiple), historial acotado a 2 procuraciones + 2 informes por caso, avisos solo in-app, gating por plan, export/import de backup del usuario. Transporte evaluado técnicamente (POST-form con patrón Post/Redirect/Get, sin límite práctico tras subir el body limit a 5MB). Plan en 2 fases: F1 backend+portal (sin release Electron), F2 visores+release.

Para retomar: leer el documento y pedir bajar la Fase 1 a plan de implementación.

8. Diferidos al lanzamiento público (por diseño, no por deuda)

#	Tarea	Detalle
L1	Activar planes BASIC/PRO/ENTERPRISE	Solo cuando el cobro esté funcionando en producción real (B3)
L2	Base de Conocimiento IA	Alimentar el asistente con 20-30 tickets reales cerrados

9. Estado de producción (verificado en esta revisión)

- [procuradortool.com](#) (landing) → **200 OK**
- [api.procuradortool.com](#) (raíz) → **404** (esperable, no hay ruta en [/](#) ; no se verificó un endpoint funcional como [/auth/login](#))
- SSL de [api.procuradortool.com](#) : certbot renueva automáticamente, vence 2026-08-28
- Repo: rama [main](#) , sin código pendiente de subir — únicamente quedan archivos sin trackear que conviene clasificar (ver §2)

10. Orden de trabajo recomendado

- C1** (fix de una línea, backend) — el más grave y el más barato de corregir.
- C2 + A1 + M4** (paquete de cobro) — prerequisite duro de B3.
- SEC-4 / M2** — enforcement real del trial, ya documentado como pre-lanzamiento.
- A4** — XSS + enumeración en forgot-password, fix rápido.
- A2 + A3** — integridad de vinculación de pagos.
- D3** — saneamiento de dependencias (empeoró desde junio, fix mayormente automático).
- A5 + A6** — requieren release de Electron, agrupar en la misma versión.
- U9.3** — investigar en staging con MP sandbox.
- Resto de medios/bajos del informe de bugs, D5 y limpieza de repo — lote de mantenimiento.
- Bitácora y L1/L2** — quedan a criterio de negocio, no técnico.